# SystemMx - Modelo de amenazas SSDLC

**Owner**: Integrante 1
**Reviewer**: Pendiente de asignación y revisión humana
**Contributors**:
**Date Generated**: Mon Nov 09 2026

# Executive Summary

## High level system description

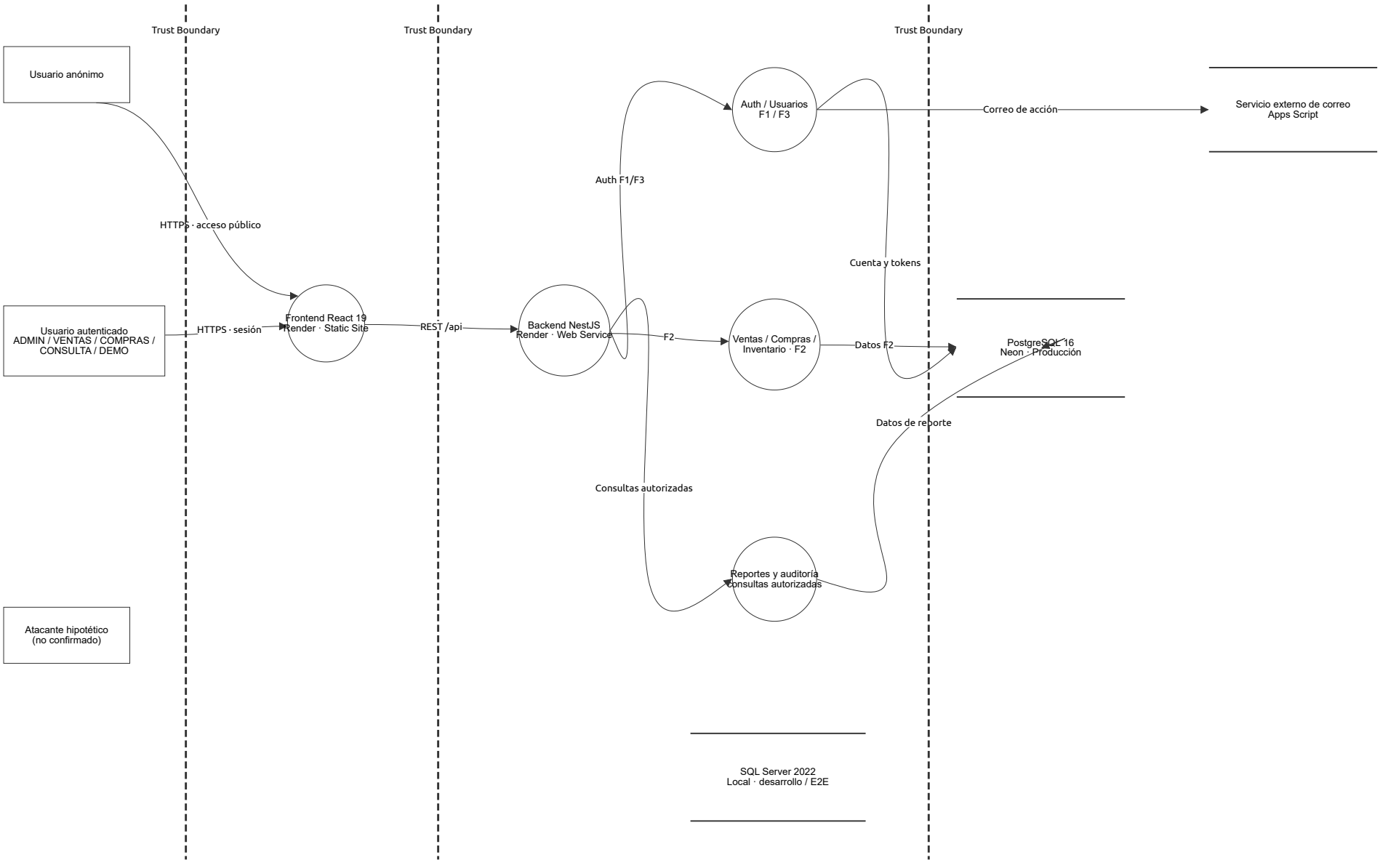
D1 STRIDE de SystemMx según el código/configuración/documentación disponibles. Producción declarada: React/Render, NestJS/Render y PostgreSQL/Neon; SQL Server local separado. Amenazas hipotéticas, no vulnerabilidades confirmadas.

## Summary

| | |
|---|---|
| **Total Threats** | 7 |
| **Total Mitigated** | 0 |
| **Total Open** | 7 |
| **Open / Critical Severity** | 0 |
| **Open / High Severity** | 5 |
| **Open / Medium Severity** | 2 |
| **Open / Low Severity** | 0 |

# D1 - Arquitectura y flujos críticos SystemMx

Topología declarada en la configuración y documentación del repositorio: frontend React en Render, backend NestJS en Render y PostgreSQL en Neon. SQL Server se representa aparte como entorno local/desarrollo/E2E. La instancia desplegada no se verificó en vivo; los escenarios STRIDE permanecen como hipótesis.



# D1 - Arquitectura y flujos críticos SystemMx

## Usuario autenticado ADMIN / VENTAS / COMPRAS / CONSULTA / DEMO (Actor)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## Usuario anónimo (Actor)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## Atacante hipotético (no confirmado) (Actor)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## Backend NestJS Render · Web Service (Process)

Description: Servicio backend desplegado según render.yaml. No se verificó el estado de una instancia en vivo.

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|
| | T-01 - Elevación de privilegios | Elevation of privilege | High | Open | P1 - cualitativo, pendiente revisión | Hipótesis: una falla de verificación de token o roles permitiría acceder a rutas no autorizadas. No confirmada; guards globales están presentes en el código. | M-01: mantener verificación JWT y rol por solicitud; preparar pruebas HTTP positivas y negativas por rol. |
| | T-07 - Denegación de servicio | Denial of service | High | Open | P2 - cualitativo, pendiente revisión | Hipótesis: automatización de rutas públicas o peticiones costosas podría degradar API, BD o correo. No confirmada. | M-07: verificar throttles detrás del proxy, límites de payload/tiempo, cuotas y monitoreo. |

## Auth / Usuarios F1 / F3 (Process)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|
| | T-02 - Suplantación y abuso de cuentas | Spoofing | High | Open | P1 - cualitativo, pendiente revisión | Hipótesis: abuso de credenciales o de recuperación/activación pública podría comprometer una cuenta. No se hizo prueba dinámica. | M-02: comprobar límites, respuestas genéricas, caducidad y consumo único de tokens en pruebas HTTP controladas. |

## Ventas / Compras / Inventario · F2 (Process)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|
| | T-04 - Alteración de ventas o existencias | Tampering | High | Open | P1 - cualitativo, pendiente revisión | Hipótesis: peticiones manipuladas o concurrentes pueden dejar importes, saldos, lotes o movimientos incoherentes. No confirmada. | M-04: revisar transacciones, concurrencia, consistencia y reconciliación con reglas aprobadas. |

## Reportes y auditoría consultas autorizadas (Process)

Description: Reportes de lectura y reportes de auditoría

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## PostgreSQL 16 Neon · Producción (Store)

Description: Persistencia PostgreSQL de producción según README y configuración Render. No se inspeccionó la base en vivo.

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|
| | T-03 - Exposición de datos comerciales | Information disclosure | High | Open | P1 - cualitativo, pendiente revisión | Hipótesis: acceso amplio a datos de usuario, ventas, pagos, costos, proveedores y stock tendría impacto comercial/privacidad. | M-03: acordar matriz por ruta y campos; probar salidas de API y reportes con roles distintos. |
| | T-05 - Repudio de operaciones | Repudiation | Medium | Open | P2 - cualitativo, pendiente revisión | Hipótesis: falta de integridad/retención demostrable en auditoría impediría atribuir cambios. | M-05: acordar política de retención y comprobar escritura y protección de trazas. |

## Servicio externo de correo Apps Script (Store)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|
| | T-06 - Exposición de token de acción | Information disclosure | Medium | Open | P2 - cualitativo, pendiente revisión | Hipótesis: una URL de invitación o recuperación filtrada podría permitir acción no autorizada. No se verificó proveedor ni logs externos. | M-06: revisar uso único y expiración, enmascarar logs y confirmar controles del receptor de correo. |

## HTTPS · sesión (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## HTTPS · acceso público (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## Auth F1/F3 (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## F2 (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## Consultas autorizadas (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## Datos F2 (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## Cuenta y tokens (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## Correo de acción (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## Datos de reporte (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## Frontend React 19 Render · Static Site (Process)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## SQL Server 2022 Local · desarrollo / E2E (Store) - *Out of Scope*

**Reason for out of scope:** Entorno local/desarrollo y E2E; no es el almacenamiento productivo en Neon y no se conecta al servicio Backend Render en este diagrama.

Description: SQL Server local para desarrollo y E2E; separado del PostgreSQL productivo en Neon.

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|

## REST /api (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|---|---|---|---|---|---|---|---|